

# 3 Physically Secure the Environment

## 3.1 Physical Security

| Control Type: Mandatory                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            | Applies to architecture: | A1 | A2 | A3 | A4 | B |
|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------|----|----|----|----|---|
|                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |                          | •  | •  | •  | •  | • |
| <p><b><u>Control Definition</u></b></p> <p><b>Control Objective:</b> Prevent unauthorised physical access to sensitive equipment, workplace environments, hosting sites, and storage.</p> <p><b>In-scope components:</b></p> <ul style="list-style-type: none"> <li>• dedicated and general-purpose operator PC, including removable equipment</li> <li>• jump server</li> <li>• on-premises or remote (that is hosted or operated by a third party, or both) hardware, including HSM and the Luna Back-up HSM, hosting a Swift-related component (including interface, GUI, Swift and customer (client) connectors)</li> <li>• on-premises or remote (that is hosted or operated by a third party, or both) hardware, hosting a customer client connector</li> <li>• on-premises or remote (that is hosted or operated by a third party, or both) hardware supporting virtualisation or cloud platform and hosting Swift-related VMs, including all the Alliance Connect Virtual VPN instances</li> <li>• All Alliance Connect VPN boxes</li> <li>• [Advisory: bridging servers (such as middleware or file transfer servers other than customer connectors) used for and <b>guardian of the secure data exchange</b> between back-office and Swift-related components]</li> </ul> <p><b>Note:</b> All Alliance Connect VPN boxes and Alliance Connect Virtual VPN instances (hosting systems or machines) must also be in an environment with appropriate physical controls as described below.</p> <p><b>Risk Drivers:</b></p> <ul style="list-style-type: none"> <li>• lack of traceability</li> <li>• unauthorised physical access</li> </ul> |                          |    |    |    |    |   |
| <p><b><u>Implementation Guidance</u></b></p> <p><b>Control Statement:</b></p> <p>Physical security controls are in place to protect access to sensitive equipment, hosting sites, and storage.</p> <p><b>Control Context:</b></p> <p>Implementing physical security controls protects against insider and external threats, and reduces opportunistic attacks enabled by access to physical systems.</p> <p><b>Implementation Guidelines:</b></p> <p>The implementation guidelines are common methods to apply the relevant control. The guidelines are a helpful way to begin an assessment but should never be considered as an audit checklist as each user's implementation may vary. Therefore, in cases where some implementation guidelines elements are not present or partially covered, mitigations as well as particular environment specificities must be considered to properly assess the overall compliance adherence level (as per the suggested guidelines or as per the alternatives).</p> <ul style="list-style-type: none"> <li>• Security of Removable Equipment           <ul style="list-style-type: none"> <li>– Sensitive removable equipment, such as PIN Entry Devices (PEDs), PED keys, Swift-related smart cards, USB Tokens, and (time-based) one-time password ((T)OTP) Devices, is supervised (that is, it</li> </ul> </li> </ul>                                                                                                                                                                                                                                                                                  |                          |    |    |    |    |   |

always remains under the control of its owner) or is securely stored. For example, it does not remain plugged in a device that is unattended.

- Sensitive removable equipment required for normal continuous operations (for example, hot swappable disks, HSM devices or Luna Backup HSM) are hosted in a data centre or, at a minimum, in a locked room.
- Back-up media (for example, tapes) is physically secured.
- Security of the Workplace Environment
  - Operator PCs are located in a secured workplace environment where access is controlled and granted only to employees and other authorised workers and visitors. A separate physical area for operator PCs to access Swift systems is not required.
  - Printers used for transactions are located in a secured workplace environment and their access is restricted.
- Security for Remote Workers (for example, teleworkers or “on call” operations staff)
  - A security policy is established to support expected use cases for remote workers. The following items are considered when establishing the policy:
    - physical security of the expected teleworking environment
    - rules for personal equipment used for Swift business purposes (for example, personal PCs cannot be used to access the Swift infrastructure, however personal mobile devices can be used as a second authentication factor)
    - security during use in public environments
    - security during public and private transport
    - equipment storage
    - unauthorised access to equipment (for example, from family or friends)
    - remote access requirements (recommended VPN with multi-factor authentication)
    - protection of mobile devices used for authentication, such as (T)OTP (recommend enabling password and auto-lock features)
    - compensating controls (for example, virtual desktop preventing local storage, full-disk encryption)
    - reporting of security incidents (for example, theft) while working remotely
- Security of the Server Environment
  - Servers are hosted in a data centre or, at a minimum, in a locked room with limited and controlled access (for example, using access control cards or biometrics).
  - Ideally, servers are rack-mounted. A risk assessment is conducted to determine if a separate and exclusive rack, or the locking of the rack, is appropriate based on the existing data centre physical access controls.
  - The Swift or customer secure zone environment has video surveillance with movement detection and recording equipment. The implementation of video surveillance recording and retention of images comply with applicable laws and regulations<sup>35</sup>. Ideally, images are retained for at least three months.
  - No physical reference to Swift on servers (for example, labels).
- Equipment Disposal
  - Consider sanitisation of the embarked data (such as secure deletion, overwriting or encryption on storage media, or manufacturer’s reset) when in-scope equipment is to be disposed of or reused.
- Physical Access Logging and Review
  - Physical access to sensitive equipment areas (for example, data centre, secured storage) is logged.
  - Physical access logs of the Swift or customer secure zone are available for audit and investigations, and are retained for a minimum of 12 months and in compliance with applicable laws and regulations.
  - Physical access is promptly revoked (or modified) when an employee changes roles or leaves the organisation.
  - Physical access control lists are reviewed annually (at least).

#### Optional Enhancement:

- Apply the control to all bridging servers (such as middleware or file transfer servers other than customer connectors) used for data exchange between back-office and Swift-related components.

<sup>35</sup> Such as the “Guidelines 3/2019 on processing of personal data through video devices”, local Data Protection Act/code of practice or Laws related to video surveillance